

Minor Project: Security Incident Detection using Splunk

Student Name: Sanvith JS

Course: SOC / Cybersecurity Fundamentals

Date: 17 May 2026

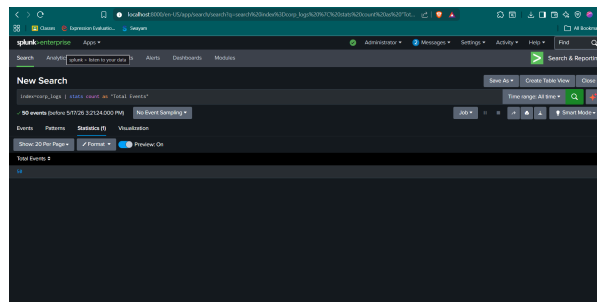
Task 1 - Ingest the Log File

- **Log File Uploaded:** windows_security_logs.evtx.txt
- **Sourcetype:** csv
- **Index Name:** corp_logs

Task 2 - Explore the Data

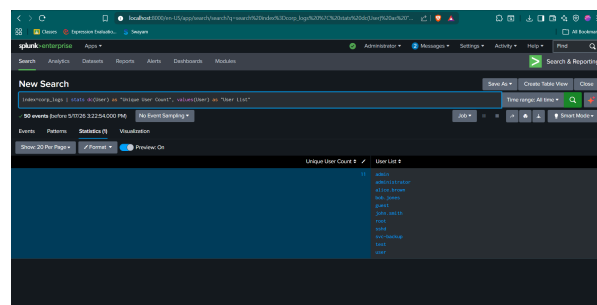
1. How many total events are in the log?

- **Answer:** There are exactly 50 total events in the log.
- **Splunk Query Used:** `index=corp_logs | stats count as "Total Events"`



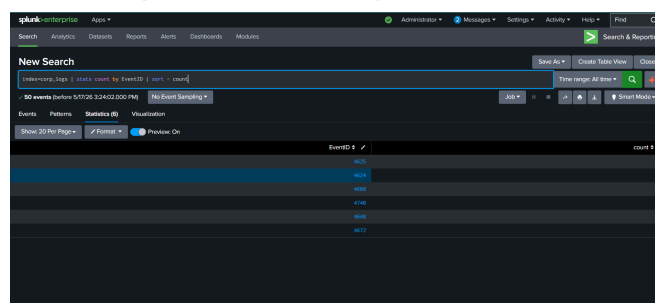
2. How many unique users appear in the logs?

- **Answer:** There are 11 unique users targeted or logging in (admin, administrator, alice.brown, bob.jones, guest, john.smith, root, sshd, svc-backup, test, user).
- **Splunk Query Used:** `index=corp_logs | stats dc(User) as "Unique User Count", values(User) as "User List"`



3. How many EventID types are present? List them.

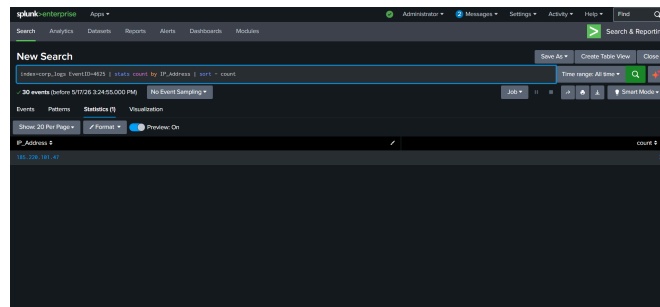
- **Answer:** There are 6 unique EventID types present:
 1. **4625** (Failed Logon Attempt)
 2. **4624** (Successful Logon)
 3. **4688** (A New Process was Created)
 4. **4740** (A User Account was Locked Out)
 5. **4648** (Logon Attempt using Explicit Credentials)
 6. **4672** (Special Privileges Assigned to New Logon)
- **Splunk Query Used:** `index=corp_logs | stats count by EventID | sort - count`



Task 3 - Detect the Anomaly

1. Which IP address stands out as suspicious? Why?

- Answer:** The IP address **185.220.101.47** stands out as highly suspicious. It is responsible for 100% of the failed authentication attempts in the logs, indicating a brute-force or password spraying attack originating from a single external source.



2. What EventID indicates a failed login? How many times did it occur from the suspicious IP?

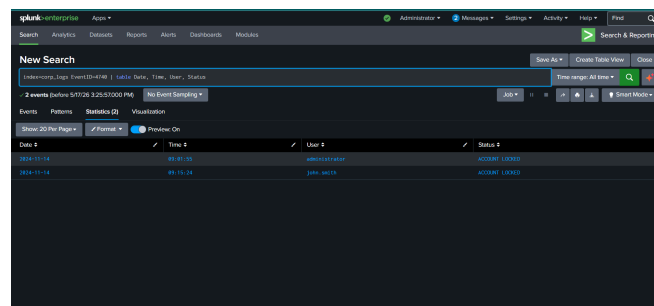
- Answer:** EventID **4625** indicates a failed login. It occurred **30 times** from the suspicious IP **185.220.101.47**.

3. Which accounts were targeted?

- Answer:** The attacker targeted 8 different accounts: **administrator** (13 times), **john.smith** (5 times), **root** (3 times), **admin** (3 times), **test** (2 times), **user** (2 times), **guest** (1 time), and **sshd** (1 time).

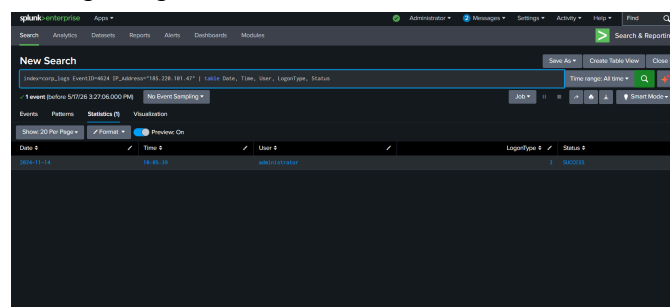
4. Were any accounts locked out? Which EventID tells you this?

- Answer:** Yes, two accounts were locked out: **administrator** (at 09:01:55) and **john.smith** (at 09:15:24). **EventID 4740** tells us when an account is locked out.



5. Did the attacker eventually succeed in logging in? How can you tell?

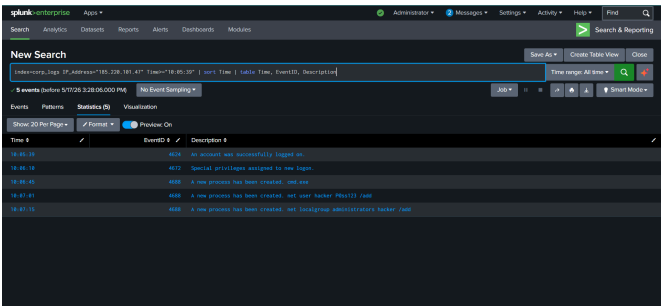
- Answer:** Yes, the attacker succeeded. We can tell because at 10:05:39, there is an **EventID 4624** (Successful Logon) for the **administrator** account originating from the attacker's IP **185.220.101.47**.



Task 4 - Post-Compromise Activity

1. What commands were run on the system? (Hint: look at EventID **4688**)

- Answer:** The attacker ran the following command-line instructions:
 - `cmd.exe` (Launched a command prompt)
 - `net user hacker P@ss123 /add` (Created a new user)
 - `net localgroup administrators hacker /add` (Added the user to the admins group)



2. What did the attacker try to do after gaining access?
- **Answer:** The attacker performed **Privilege Escalation** and established **Persistence**. By creating a hidden backdoor account and making it an administrator, they ensured they would keep top-level access to the domain controller even if the original `administrator` password was changed by the IT team.
3. What new account was created?
- **Answer:** A new rogue account named `hacker` was created.

Task 5 - Incident Report

INCIDENT REPORT: DOMAIN CONTROLLER COMPROMISE

Report ID: IR-2024-11-14-001
Severity: CRITICAL

1. Executive Summary

Between 09:00 and 10:07 AM on November 14, 2024, the Domain Controller `CORP-DC01` experienced a severe security breach. An external threat actor conducted a hybrid brute-force and password spraying attack, successfully compromising the primary `administrator` account. Following the breach, the attacker established persistent backdoor access by creating a rogue administrative user.

2. Incident Timeline (Cyber Kill Chain)

- **09:00 - 09:15:** Rapid password spraying/brute-force attack.
- **09:01 & 09:15:** `administrator` and `john.smith` accounts locked out (EventID 4740).
- **10:05:39: [SYSTEM BREACHED]** Attacker successfully logged in as `administrator` (EventID 4624).
- **10:07:01:** Attacker launched `cmd.exe` and created a hidden account via `net user hacker Ph4st0r! /add` (EventID 4688).
- **10:07:15:** Privilege escalation granted to `hacker` via `net localgroup administrators` (EventID 4688).

3. Threat Intelligence / IOCs

- **Malicious IP Address:** `185.220.101.47` (IPv4)
- **Targeted Accounts:** `administrator`, `john.smith`, `root`, `admin`, `guest`, `sshd`, `test`, `user`
- **Compromised Asset:** `CORP-DC01` (Domain Controller)
- **Rogue Account Identified:** `hacker` (Host IOC)

4. Impact Analysis (CIA Triad)

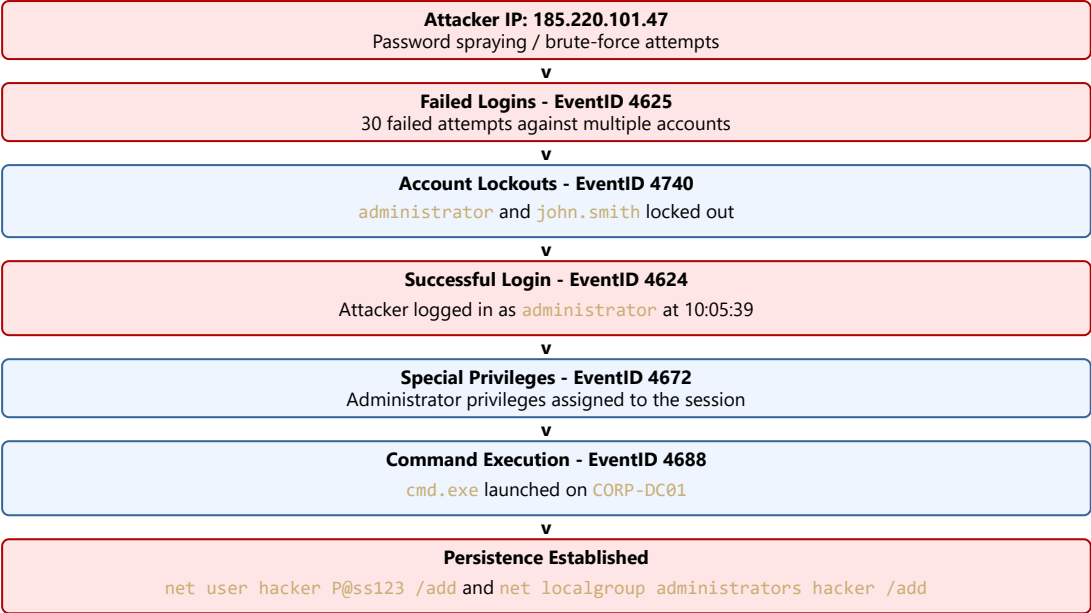
- **Confidentiality:** Compromised. The adversary gained Domain Admin access, enabling them to read or exfiltrate any sensitive data.
- **Integrity:** Compromised. The adversary altered system configurations by creating a rogue user (`hacker`) and modifying the `administrators` group.
- **Availability:** At Risk. The adversary has the necessary privileges to take the system offline or deploy ransomware.

5. Containment & Remediation Recommendations

1. **Immediate Action:** Disconnect `CORP-DC01` from the internet and isolate it from the internal network immediately.
2. **Account Remediation:** Delete the rogue `hacker` account immediately. Force a global password reset for all domain accounts.
3. **Firewall Blocking:** Blacklist the IP address `185.220.101.47` at the perimeter firewall (Geo-blocking recommended).
4. **Policy Hardening:** Implement Multi-Factor Authentication (MFA) and Zero Trust Architecture for all remote access logins. Increase the Account Lockout duration policy.
5. **SIEM Alerting:** Create Splunk detection rules to trigger high-severity alerts whenever `net localgroup administrators` is executed in EventID 4688.

Advanced Technical Analysis (Bonus)

Attack Flow Diagram:



MITRE ATT&CK Framework Mapping:

Tactic	Technique ID	Technique Name	Evidence in Log
Credential Access	T1110.001	Brute Force: Password Guessing	Repeated EventID 4625 (Wrong Password).
Initial Access	T1078.002	Valid Accounts: Domain Accounts	EventID 4624 (Successful Logon) by attacker.
Persistence	T1136.001	Create Account: Local Account	EventID 4688 showing net user hacker... /add.
Privilege Escalation	T1078.002	Valid Accounts: Local Accounts	EventID 4688 adding hacker to administrators group.